گزارش ممیزی امنیتی و تست نفوذ

سامانه‌ی مدیریت وظایف و تیم «تسکام» (Taskam v2)

نسخه‌ی بررسی‌شده: `v7.3.0`

نوع ارزیابی: ممیزی امنیتی جعبه‌خاکستری + تست نفوذ پویا

چارچوب: OWASP Top 10 (2021) و OWASP API Security Top 10 (2023)

تاریخ گزارش: ۱۴۰۴/۰۸/۱۹ (10-11-2026)

محیط: نسخه‌ی ایزوله‌ی تست روی `127.0.0.1` با دیتابیس آزمایشی

این گزارش محرمانه است و صرفاً برای تیم فنی تسکام تهیه شده است.

فهرست مطالب

1. خلاصه‌ی مدیریتی
2. روش‌شناسی تست نفوذ
3. مشخصات محیط آزمایش و محدوده
4. آمار آسیب‌پذیری‌ها
5. جدول خلاصه‌ی یافته‌ها
6. جزئیات آسیب‌پذیری‌های شناسایی‌شده
7. نتایج تست احراز هویت و نشست
8. نتایج تست سطح دسترسی (IDOR/BOLA/BFLA)
9. نتایج تست SQL Injection
1. نتایج تست XSS
1. نتایج تست امنیت API و توکن
1. نتایج تحلیل Rate Limit
1. نتایج تست آپلود فایل
1. نتایج تست منطق تجاری
1. امنیت دیتابیس، سرور و پیکربندی
1. موارد بررسی‌نشده / محدودیت‌ها
1. جمع‌بندی و ارزیابی نهایی

۱. خلاصه‌ی مدیریتی

سامانه‌ی تسکام در این ارزیابی از نظر امنیتی **بسیار مستحکم** ارزیابی شد. هیچ آسیب‌پذیری بحرانی یا بالایی که امکان دسترسی غیرمجاز به داده‌ی کاربران دیگر، اجرای کد، یا دور زدن احراز هویت را بدهد، بازتولید نشد. مجموعه‌ای کامل از دفاع‌های استاندارد (شناسه‌ی عمومی غیرقابل‌حدس، لایه‌ی واحد تصمیم دسترسی، کوئری‌های پارامتری، فرار خروجی، CSP سخت‌گیرانه، throttle، CSRF چندلایه) به‌درستی پیاده و از طریق تست پویا تأیید شد.

در مجموع **۵** یافته ثبت شد که هیچ‌کدام بحرانی/بالا نیستند: **یک** مورد با شدت «متوسط» (عدم تفکیک نقش‌های مدیر — که در مستندات پروژه هم به‌عنوان کار باز شناخته شده)، **یک** مورد «پایین» (ورود به پنل کاربر بدون رمز مجدد)، و **سه** مورد «اطلاعاتی» که بیشتر تصمیم‌های طراحی‌اند تا نقص. تمام یافته‌های دسترسی درون گروه «مدیران مورد اعتماد» باقی می‌مانند و توسط سازوکار لاگ کامل (`admin_logs`) پوشش داده می‌شوند.

بحرانی	بالا	متوسط	پایین	اطلاعاتی
0	0	1	1	3

⚠ یادآوری روش‌شناسی: نبود آسیب‌پذیری در تست‌های انجام‌شده به معنای امنیت کامل و مطلق سامانه نیست. ارزیابی در محدوده و زمان مشخص انجام شده و هر یافته با بازتولید عملی مستند شده است — هیچ ادعای آسیب‌پذیری صرفاً از روی خواندن کد ثبت نشده است.

۲. روش‌شناسی تست نفوذ

ارزیابی به‌صورت **جعبه‌خاکستری** (دسترسی به سورس + تست پویای زنده) و بر پایه‌ی OWASP انجام شد. گام‌ها:

- دریافت آخرین نسخه از مخزن GitHub و بررسی معماری (PHP MVC بدون فریم‌ورک، لایه‌های Controller/Service/Model).
- برپایی نسخه‌ی ایزوله روی سرور محلی با دیتابیس آزمایشی مستقل (بدون هیچ ارتباط با محیط واقعی).
- ساخت چند حساب با نقش‌های متفاوت (مدیر کل، مدیر پشتیبان، دو کاربر عادی) برای تست دسترسی افقی و عمودی.
- استخراج کامل نقشه‌ی مسیرها (routes) و میدلورها.
- تست پویا با `curl` روی هر دسته‌ی OWASP؛ هر یافته با درخواست/پاسخ واقعی بازتولید شد.
- بازبینی کد در نقاط حساس (Access، Uploader، Search، Session، Auth، Impersonation) برای هدایت تست‌ها.

محدودیت‌های اخلاقی رعایت‌شده: هیچ حمله‌ی منع سرویس، سیل درخواست، استخراج انبوه یا تخریب زیرساخت انجام نشد. همه‌ی payloadها کنترل‌شده و بی‌خطر بودند و فقط روی داده‌ی آزمایشی اجرا شدند.

۳. مشخصات محیط آزمایش و محدوده

مؤلفه	مقدار
نسخه‌ی برنامه	`v7.3.0`

PHP	8.3.6
پایگاه‌داده	MariaDB (دیتابیس آزمایشی taskam_test)
آدرس تست	http://127.0.0.1:8080
حساب‌های تست	مدیر کل (۰۹۱۲۰۰۰۰۰۰۰)، مدیر پشتیبان (۰۹۱۲۰۰۰۰۰۷۷)، کاربر A، کاربر B
تغییرات محیط تست	CAPTCHA_LOGIN=false و APP_DEBUG=true (فقط برای خودکارسازی تست؛ در تحلیل، رفتار تولید هم بررسی شد)

محدوده: کل پنل کاربر، پنل مدیر و REST API نسخه‌ی ۱. **خارج از محدوده:** زیرساخت سرور واقعی، تنظیمات Web Server تولید، و سرویس‌های جانبی (Web Push/VAPID به‌صورت سطحی).

۴. آمار آسیب‌پذیری‌های شناسایی‌شده

شدت	تعداد	توضیح
بحرانی	0	موردی یافت نشد
بالا	0	موردی یافت نشد
متوسط	1	عدم تفکیک نقش‌های مدیر
پایین	1	ورود به پنل کاربر بدون رمز مجدد
اطلاعاتی	3	تصاویر عمومی، وابستگی به کپچا، تاریخچه‌ی چت پس از بلاک

۵. جدول خلاصه‌ی یافته‌ها

شناسه	آسیب‌پذیری	دسته	شدت	CVSS	وضعیت
SEC-001	عدم تفکیک دسترسی بین نقش‌های مدیر (همه‌ی نقش‌ها دسترسی کامل دارند)	Authorization / BFLA	متوسط	6.8	تأییدشده (Confirmed)
SEC-002	ورود به پنل کاربر (Impersonation) بدون احراز هویت مجدد رمز عبور	Authentication / Business Logic	پایین	3.4	تأییدشده (Confirmed)
SEC-003	مشاهده‌ی تصویر پروفایل/پروژه‌ی هر کاربر توسط هر کاربر واردشده	Access Control / Information Exposure	اطلاعاتی	-	تأییدشده (Confirmed) — رفتار طراحی‌شده
SEC-004	وابستگی دفاع در برابر Brute-Force به تنظیم کپچا	Authentication / Configuration	اطلاعاتی	-	اطلاعاتی
SEC-005	خواندن پیام‌های قبلی چت پس از مسدودسازی همکار	Business Logic / Privacy	اطلاعاتی	-	تأییدشده (Confirmed) — رفتار طراحی‌شده

۶. جزئیات آسیب‌پذیری‌های شناسایی‌شده

SEC-001 — عدم تفکیک دسترسی بین نقش‌های مدیر (همه‌ی نقش‌ها دسترسی کامل دارند)

شدت	متوسط	**دسته**	Authorization / BFLA	**CVSS v4.0** 6.8

Vector `CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:H/VI:H/VA:L/SC:N/SI:N/SA:N`

وضعیت اعتبارسنجی تأییدشده (Confirmed)

شرح

سه نقش مدیریتی تعریف شده است: «مدیر کل» (super)، «مدیر داخلی» (internal) و «پشتیبان» (support). اما در پیاده‌سازی فعلی، هر سه نقش **تمام** مجوزهای مدیریتی (`Auth::ADMIN_PERMS`) را می‌گیرند. در نتیجه یک حساب با نقش «پشتیبان» که انتظار می‌رود فقط به تیکت‌ها دسترسی داشته باشد، می‌تواند به لاگ امنیتی، فهرست ورود به‌جای کاربر، آنالیز، و حتی عملیات حساس مانند «ورود به پنل کاربر» (impersonate)، حذف کاربر و ویرایش محتوا دسترسی پیدا کند. این نقض اصل «کمترین امتیاز» (Least Privilege) است.

محل در پنل

پنل مدیر ← همه‌ی صفحات مدیریتی (تنظیمات ← امنیت، ورود به پنل کاربر، آنالیز، کاربران)

محل در سورس

`app/Core/Auth.php → adminPermissions()/ADMIN_PERMS ؛ app/Middleware/RequireAdmin.php ؛ AdminController::need()`

بازتولید (PoC)

```
# ساخت حساب مدیر با نقش پایین (support)
INSERT INTO users (...,role,admin_role) VALUES (...,'admin','support');

# ورود و دسترسی به صفحات مدیر کل:
GET /admin/security       -> HTTP 200   (باید محدود باشد)
GET /admin/impersonations -> HTTP 200
GET /admin/analysis       -> HTTP 200

# ورود به‌جای یک کاربر عادی:
POST /admin/users/<pid>/impersonate
-> {"status":"success","open":"/as/7367cdfb.../dashboard"}  HTTP 200
```

تأثیر امنیتی

یک مدیر با نقش محدود (مثلاً پشتیبان که ممکن است به پیمانکار بیرونی سپرده شود) می‌تواند فراتر از وظیفه‌ی خود عمل کند: ورود به حساب هر کاربر، مشاهده‌ی لاگ‌های امنیتی، حذف کاربران و تغییر محتوای پنل. در صورت لو رفتن یا سوءاستفاده‌ی یک حساب کم‌دسترسی، کل سیستم در معرض خطر است.

راهکار پیشنهادی

مجوزها را بر اساس نقش تفکیک کنید: یک نگاشت `ROLE => [perms]` تعریف شود و `adminPermissions()` فقط مجوزهای همان نقش را برگرداند (مثلاً support تنها `support` ؛ عملیات impersonate/حذف کاربر/امنیت فقط برای super). میدلور و `need()` همین نگاشت را بررسی کنند. (این مورد در `CLAUDE.md` / `docs/SECURITY.md` به‌عنوان کار باز مستند شده است.)

یادداشت

این رفتار در مستندات پروژه به‌صراحت به‌عنوان یک محدودیت موقت و کار آینده ذکر شده است. همه‌ی اقدامات درون این دسترسی در `admin_logs` ثبت می‌شود و فقط برای کسی که از قبل عضو گروه مدیران مورد اعتماد است قابل بهره‌برداری است؛ به همین دلیل شدت «متوسط» ارزیابی شد نه بالاتر.

SEC-002 — ورود به پنل کاربر (Impersonation) بدون احراز هویت مجدد رمز عبور

شدت	پایین	**دسته**	Authentication / Business Logic	**CVSS v4.0**	3.4

Vector `CVSS:4.0/AV:N/AC:L/AT:N/PR:H/UI:N/VC:L/VI:L/VA:N/SC:N/SI:N/SA:N`

وضعیت اعتبارسنجی تأییدشده (Confirmed)

شرح

از نسخه‌ی v5.2 به بعد، «ورود به پنل کاربر» دیگر نیازی به وارد کردن مجدد رمز عبور مدیر ندارد. اگر نشست یک مدیر ربوده شود (یا یک ایستگاه کاری بدون قفل رها شود)، مهاجم می‌تواند بدون هیچ مانعی وارد پنل هر کاربر شود و به داده‌های او دسترسی یابد.

محل در پنل

پنل مدیر ← فهرست کاربران ← منوی ⋮ ← «ورود به پنل کاربر»

محل در سورس

`app/Controllers/AdminController.php::impersonate()` ؛ `app/Core/Impersonation.php::start()`

بازتولید (PoC)

```
POST /admin/users/<userPid>/impersonate   (فقط با نشست مدیر، بدون رمز)
-> {"status":"success","open":"/as/<token>/dashboard"}
```

تأثیر امنیتی

افزایش سطح دسترسی از «نشست مدیر لو رفته» به «دسترسی کامل به حساب کاربران». هرچند خودِ ورودِ مدیر لازم است، نبود گام تأیید دوباره، پنجره‌ی سوءاستفاده را باز می‌کند.

راهکار پیشنهادی

برای شروع impersonation یک گام احراز هویت مجدد (ورود دوباره‌ی رمز مدیر یا تأیید دوعاملی) اضافه شود؛ مشابه کاری که برای تغییر رمز/موبایل کاربر توسط مدیر از قبل الزام شده است.

یادداشت

کاهنده‌ها: نشست فعال مدیر لازم است، هر پنجره محدودیت زمانی بی‌فعالیتی (۳۰ دقیقه) و سقف عمر (۴ ساعت) دارد، نرخ آن محدود است (۳۰ بار در ساعت)، و تمام فعالیت‌ها در `admin_logs` با snapshot قبل/بعد ثبت می‌شود. به همین دلیل شدت «پایین» است.

SEC-003 — مشاهده‌ی تصویر پروفایل/پروژه‌ی هر کاربر توسط هر کاربر واردشده

شدت	اطلاعاتی	**دسته**	Access Control / Information Exposure	**CVSS v4.0** -

وضعیت اعتبارسنجی تأییدشده (Confirmed) — رفتار طراحی‌شده

شرح

در `FileController::allowed()` برای نوع‌های `avatars` و `projects` مقدار `true` بدون بررسی مالکیت برگردانده می‌شود؛ یعنی هر کاربر واردشده می‌تواند تصویر پروفایل یا پروژه‌ی هر کاربر دیگر را در صورت دانستن نام فایل ببیند.

محل در پنل

GET /files/avatars/{name} و /files/projects/{name}

محل در سورس

```
app/Controllers/FileController.php::allowed() (case 'avatars'/'projects')
```

بازتولید (PoC)

```
GET /files/avatars/<randomname>.jpg  -> HTTP 200 (هر کاربر واردشده)
```

تأثیر امنیتی

بسیار محدود: نام فایل‌ها تصادفی و غیرقابل‌حدس‌اند (۵۱۲px، نام یکتا) و تصاویر پروفایل ذاتاً داده‌ی حساسی نیستند. امکان شمارش (enumeration) فایل‌ها وجود ندارد.

راهکار پیشنهادی

اگر محرمانگی تصاویر پروژه مهم است، دسترسی را به اعضای همان پروژه محدود کنید؛ در غیر این صورت این رفتار قابل‌قبول و آگاهانه است.

یادداشت

این رفتار در کد به‌صراحت کامنت شده: «تصاویر پروفایل برای کاربران واردشده قابل مشاهده است». تنها به‌عنوان یادداشت اطلاعاتی ثبت شد.

SEC-004 — وابستگی دفاع در برابر Brute-Force به تنظیم کپچا

شدت	دسته	CVSS v4.0
اطلاعاتی	Authentication / Configuration	-

وضعیت اعتبارسنجی اطلاعاتی

شرح

کپچای تصویری صفحه‌ی ورود با متغیر `CAPTCHA_LOGIN` کنترل می‌شود (پیش‌فرض روشن). در محیط تست برای خودکارسازی خاموش شد. اگر در محیط واقعی خاموش بماند، تنها خط دفاعی در برابر حدس رمز، سازوکار throttle است.

محل در پنل

صفحه‌ی ورود /login

محل در سورس

```
.env → CAPTCHA_LOGIN ؛ app/Core/Captcha.php
```

بازتولید (PoC)

```
– (پیکربندی)
```

تأثیر امنیتی

در صورت خاموش بودن کپچا، مهاجم تا سقف throttle (۵ تلاش در ۱۵ دقیقه برای هر موبایل+IP) می‌تواند تلاش کند. این سقف قوی است، اما کپچا لایه‌ی دفاعی مهمی است.

راهکار پیشنهادی

اطمینان از `CAPTCHA_LOGIN=true` در محیط واقعی (که پیش‌فرض است). این مورد صرفاً یادآوری پیکربندی است.

یادداشت

سازوکار throttle (SEC/تست بخش ۱۴) به‌درستی کار می‌کند؛ این یادداشت فقط برای کامل بودن است.

SEC-005 — خواندن پیام‌های قبلی چت پس از مسدودسازی همکار

شدت	اطلاعاتی	**دسته**	Business Logic / Privacy	**CVSS v4.0**	-

وضعیت اعتبارسنجی تأییدشده (Confirmed) — رفتار طراحی‌شده

شرح

در `ChatController::fetch()` پس از مسدود کردن یک کاربر، پیام‌های ردوبدل‌شده‌ی قبلی همچنان برای دو طرف قابل خواندن است؛ تنها ارسال پیام جدید بسته می‌شود.

محل در پنل

چت ← گفتگوی مسدودشده

محل در سورس

`app/Controllers/ChatController.php::fetch()`

بازتولید (PoC)

```
GET /chat/api/fetch?user_id=<pid>  همچنان تاریخچه را برمی‌گرداند  پس از block
```

تأثیر امنیتی

ناچیز؛ این داده قبلاً برای هر دو طرف قابل دسترس بوده است. مسدودسازی مانع تعامل جدید می‌شود، نه بازنگری تاریخچه.

راهکار پیشنهادی

اگر سیاست محصول «پنهان‌سازی کامل پس از بلاک» است، نمایش تاریخچه را هم محدود کنید؛ در غیر این صورت رفتار فعلی منطقی است.

یادداشت

در کد کامنت شده: «بعد از مسدودی، پیام‌های قبلی همچنان قابل خواندن است (فقط ارسال بسته است)».

۷. نتایج تست احراز هویت و نشست

امن **احراز هویت (Authentication)**

ورود بدون اعتبار معتبر ناممکن است؛ تأیید رمز با `password_verify` و هش ساختگی برای یکسان‌سازی زمان پاسخ (جلوگیری از افشای وجود حساب از طریق timing)؛ نشست هنگام ورود موفق بازتولید می‌شود (بدون Session Fixation)؛ خروج، نشست را سمت سرور باطل می‌کند و کوکی قدیمی دیگر کار نمی‌کند.

امن **مدیریت نشست (Session)**

کوکی `Secure` ، `SameSite=Lax` ، `HttpOnly` روی HTTPS؛ شناسه‌ی نشست فقط به‌صورت SHA-256 در جدول `user_sessions` ذخیره می‌شود؛ اتصال نشست به پیشوند IP و مرورگر؛ انقضای لغزنده و چرخش دوره‌ای؛ ورود از شبکه‌ی جدید نیاز به `/reauth` دارد.

امن **توکن API**

توکن‌ها به‌صورت SHA-256 ذخیره می‌شوند؛ محدوده‌ی `read` / `write` اعمال می‌شود (توکن فقط‌خواندنی نمی‌تواند بنویسد → 403)؛ توکن منقضی/غیرفعال/با فرمت نادرست رد می‌شود (401)؛ throttle برای توکن نامعتبر (۲۰ خطا در ۱۰ دقیقه).

۸. نتایج تست سطح دسترسی (IDOR / BOLA / BFLA)

امن **کنترل دسترسی افقی (IDOR/BOLA)**

تلاش کاربر B برای خواندن/ویرایش تسک، پروژه، تیکت، یادداشت و پیام چتِ کاربر A در همه‌ی موارد ۴۰۴/۴۰۳ گرفت. تسک محرمانه حتی با «لینک اشتراکی» برای اعضای غیرمجاز باز نشد. سیستم شناسه‌های عمومی (pid) شناسه‌ی عددی داخلی را از بیرون نمی‌پذیرد (تلاش با id عددی = «شناسه نامعتبر»).

امن **کنترل دسترسی عمودی (BFLA)**

کاربر عادی به تمام endpointهای مدیر ۴۰۳ گرفت؛ تلاش‌های ارتقای سطح (ساخت خود به مدیر، impersonate، حذف کاربر) همگی ۴۰۳ شدند و کاربر عادی باقی ماند. فیلدهای حساس (`admin_role` , `status` , `is_bot`) از طریق به‌روزرسانی پروفایل قابل تنظیم نیستند (Mass Assignment بسته است — همه‌ی به‌روزرسانی‌ها فهرست صریح فیلد دارند).

۹. نتایج تست SQL Injection

امن **تزریق SQL**

تمام کوئری‌ها Prepared Statement هستند؛ ساخت فیلتر/مرتب‌سازی/جستجو پارامتری یا از فهرست ثابت است (`$order` از switch با رشته‌های ثابت). تست‌های ۰٫۰۲ → Time-based (`SLEEP(3)`)، Boolean-based (`' OR '1'='1`) ،Error-based ثانیه) و تزریق پارامتر `sort` / `project` همگی بی‌اثر بودند و هیچ خطای SQL افشا نشد.

۱۰. نتایج تست XSS

XSS امن

endpointهای جزئیات خروجی `application/json` می‌دهند (نه HTML)؛ در صفحات سمت‌سرور ورودی با `e()` فرار داده می‌شود؛ بلوک JSON راه‌انداز با `\u003C` کدگذاری می‌شود (جلوگیری از شکست `</script>`)؛ پنل مدیر هم محتوای کاربر را فرار می‌دهد؛ نام کاربری حاوی `<>` در اعتبارسنجی رد می‌شود. CSP سخت‌گیرانه (`script-src 'self'`) به‌عنوان لایه‌ی دوم.

۱۱. نتایج تست امنیت API و توکن

توکن API امن

توکن‌ها به‌صورت SHA-256 ذخیره می‌شوند؛ محدوده‌ی `read` / `write` اعمال می‌شود (توکن فقط‌خواندنی نمی‌تواند بنویسد → 403)؛ توکن منقضی/غیرفعال/با فرمت نادرست رد می‌شود (401)؛ throttle برای توکن نامعتبر (۲۰ خطا در ۱۰ دقیقه).

هدرها / CORS / Open Redirect امن

برای Origin ناشناس هیچ هدر `Access-Control-Allow-Origin` صادر نشد؛ هیچ پارامتر `to/next/redirect` برای تغییر مسیر پذیرفته نشد؛ پارامتر `to` در impersonation با regex سخت‌گیرانه فقط به `/tasks|/board|/projects` محدود است. هدرهای امنیتی کامل‌اند: CSP, X-Frame-Options: DENY, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, COOP/CORP و HSTS (روی HTTPS).

۱۲. نتایج تحلیل Rate Limit

Rate Limiting امن

محدودیت ورود (۵ تلاش در ۱۵ دقیقه برای موبایل+IP) دقیقاً کار کرد؛ قفل حساب فقط برای حمله‌ی توزیع‌شده؛ API دقیقاً ۱۲۰ درخواست در دقیقه سپس ۴۲۹؛ جعل `X-Forwarded-For` محدودیت را دور نزد (چون `TRUSTED_PROXY=false`).

۱۳. نتایج تست آپلود فایل

آپلود فایل امن

whitelist پسوند + بررسی MIME واقعی با `finfo` + نام تصادفی + ذخیره خارج از webroot + سروِ sandbox شده. آپلود `.svg` ، `.php` ، فایل (PNG+PHP) polyglot و پسوند دوگانه (`.php.txt`) همگی رد شدند. سروِ فایل‌ها با `Content-Security-Policy: sandbox` و `X-Content-Type-Options: nosniff` و MIME ثابت.

۱۴. نتایج تست منطق تجاری (Business Logic)

منطق تجاری / گردش کار امن

تسک نمی‌تواند مستقیم به «done» برود (ترتیب مراحل اجباری)؛ تفکیک وظایف رعایت می‌شود (تحویل‌دهنده نمی‌تواند تسک خود را تأیید کند)؛ تسک پروژه فقط به اعضای همان پروژه قابل واگذاری است؛ افزودن عضو نیازمند رابطه‌ی همکار تأییدشده است.

۱۵. امنیت دیتابیس، سرور و پیکربندی

مدیریت خطا امن

در حالت تولید (`APP_DEBUG=false`) پیام عمومی «خطای داخلی سرور» بدون stack trace یا مسیر فایل برگردانده می‌شود؛ در حالت debug فقط `basename` فایل نمایش داده می‌شود.

CSRF امن

روی همه‌ی POSTهای تغییردهنده اعمال می‌شود (بدون توکن یا با توکن اشتباه → ۴۱۹)، حتی روی `/logout` .

CORS / Open Redirect / هدرها امن

برای Origin ناشناس هیچ هدر `Access-Control-Allow-Origin` صادر نشد؛ هیچ پارامتر `to/next/redirect` برای تغییر مسیر پذیرفته نشد؛ پارامتر `to` در impersonation با regex سخت‌گیرانه فقط به `/tasks|/board|/projects` محدود است. هدرهای امنیتی کامل‌اند: CSP, X-Frame-Options: DENY, X-Content-Type-Options, Referrer-Policy, Permissions-Policy, COOP/CORP و HSTS (روی HTTPS).

یادداشت‌های امنیت دیتابیس

- شناسه‌های عددی داخلی هرگز از سرور خارج نمی‌شوند (سیستم `pid`)؛ کلیدهای خارجی عددی می‌مانند اما ورودی/خروجی ترجمه می‌شود.
- شناسه‌ی نشست فقط به‌صورت هش SHA-256 ذخیره می‌شود؛ نشت بکاپ، کوکی قابل‌استفاده نمی‌دهد.
- پیام‌های چت با AES-256-GCM رمزنگاری می‌شوند.
- رمز عبور با (bcrypt/argon) `password_hash` و rehash خودکار ذخیره می‌شود.
- توصیه‌ی عملیاتی: در تولید از کاربر دیتابیس بدون مجوز `ALTER/CREATE` استفاده شود (+ `SCHEMA_AUTO=false` `bin/migrate.php`) و `.env` و `storage/vapid.json` هرگز کامیت نشوند.

۱۶. موارد بررسی‌نشده / محدودیت‌ها

- اعلان‌های Web Push/VAPID فقط به‌صورت سطحی بررسی شد (نیازمند کلید و مرورگر واقعی).
- تنظیمات Web Server تولید (Apache/Nginx, `.htaccess` , TLS) خارج از محیط تست محلی بود.
- اسکن وابستگی‌های شخص‌ثالث: پروژه بدون Composer و تقریباً بدون وابستگی خارجی است؛ فونت/آیکون‌ها self-host هستند. سطح حمله‌ی زنجیره‌ی تأمین بسیار کم است.

- تست حجمی/بار و رقابتی (Race Condition) عمیق روی عملیات هم‌زمان مالی‌گونه انجام نشد (سامانه تراکنش مالی ندارد).
- ارزیابی در بازه‌ی زمانی محدود انجام شد؛ همان‌طور که ذکر شد، نبود یافته به معنای امنیت مطلق نیست.

۱۷. جمع‌بندی و ارزیابی نهایی امنیت

وضعیت امنیتی کلی تسکام v7.3.0: **قوی**. معماری با رویکرد امنیت‌محور طراحی شده و دفاع‌ها در عمل (نه فقط در کد) تأیید شدند. موارد یافت‌شده عمدتاً به تفکیک دقیق‌تر نقش‌های مدیر و سخت‌گیری بیشتر در عملیات مدیریتی مربوط‌اند، نه به نقص‌های پایه‌ای.

اولویت اقدام پیشنهادی

1. **SEC-001 (متوسط):** پیاده‌سازی تفکیک مجوز بر اساس نقش مدیر — مهم‌ترین اقدام.
2. **SEC-002 (پایین):** افزودن تأیید رمز/دوعاملی پیش از ورود به پنل کاربر.
3. **SEC-003/004/005 (اطلاعاتی):** بازبینی تصمیم‌های طراحی در صورت تغییر نیازمندی محصول؛ اطمینان از روشن بودن کپچا در تولید.

پایان گزارش — تهیه‌شده برای تیم فنی تسکام. همه‌ی یافته‌ها با بازتولید عملی روی نسخه‌ی ایزوله مستند شده‌اند.